FIRST TECHNICAL COLLOQUIUM · BANGALORE 2027

Supporting brief for a 30-minute talk proposal

Claim Discipline for Multi-Host Campaign Correlation: Sealed Packs, External Corpora, Named Failures, and Machine-Checked Field Language

Speaker: Siddarth Boggarapu · Bangalore, India

siddarthb078@gmail.com · github.com/Siddarthb07/corvex

Format: Presentation (30 min + 5 min Q&A) · Language: English · TLP:CLEAR · Open tooling

CFS window: opens 5 Oct 2026 · deadline 21 Nov 2026 · notifications week of 8 Dec 2026

Standing claim (locked)

Corvex holds up on synthetic ATT&CK-shaped fleets and externally authored lab purple-team captures. It is **not** validated on real enterprise telemetry or pure-benign home-lab baselines. Machine gate **claim_allowed=false** until live second-host evidence exists. This brief does not sell a product.

How to use this PDF

FIRST does not require a formal paper. Section 1 is the CFS-ready abstract and detailed outline you can paste into the submission form. The rest is optional supporting material for program-committee review and for building the live talk: readable numbers, failure mechanisms, and takeaways an IR/SOC team can reuse without adopting Corvex.

Contents

1. CFS packet - title, abstract, outline, speaker note, topic fit
2. The problem in plain language - lab scores that become field sentences
3. What Corvex is (and is not)
4. Evaluation protocol - seal, ablate, breaktest, external OTRF, claim gate
5. Results - sealed, breaktest, OTRF aggressive, live laptop replay
6. What broke and why - mechanisms, not bare labels
7. What IR teams can steal tomorrow
8. Limits, venue map, reproduce

Appendix - why an earlier academic packaging was rejected

1. CFS packet (paste-ready)

Proposed talk title

When F1=1.00 Still Lies: Claim Gates, External Purple-Team Corpora, and Honest Multi-Host Campaign Correlation

Suggested FIRST topic buckets

- Primary: **Detection, Threat Intelligence and Adversary Analysis** (campaign correlation, measurable detection lift, ATT&CK-shaped fleets).
- Secondary: **Defending the Defenders** (how detection tooling overclaims; claim gates as anti-self-deception).
- Secondary: **Human-Machine Incident Response** (automation that refuses field language until evidence exists).

Abstract (approx. 145 words - under 250 max)

Security tools often look excellent on author-written lab packs, then soft-upgrade into "works in production" language. This talk is a practitioner experience report on stopping that drift. Using Corvex - an open-source multi-host campaign correlator that fuses weak per-host detectors via HMAC-signed events - we show a five-part discipline: seal held-out packs, ablate fusion against detector-only baselines, score harder public-TTP breaktests, lead independence claims with externally authored OTRF / MITRE ATT&CK Evals captures (APT29, Caldera APT3, Golden SAML), and lock field language behind a machine-checked claim gate that stays false without live second-host evidence. We corrected an inconsistent F1 bug, report sealed correlator micro-F1 1.00 dropping to breaktest ~0.65, show 4 fusion holds on hardest compounds after named fixes, and stream 56 OTRF captures into a live correlator with 0 miss (replay, not malware execution). Attendees leave with a reusable claim checklist - not a product pitch.

Detailed outline (approx. 420 words)

0-3 min - Hook. Show a sealed lab table with correlator F1=1.00 next to a drafted README sentence that soft-claims "multi-host attacks in the enterprise." Run the claim gate: blocked. Problem statement: scores are not sentences.

3-8 min - System sketch (short). Corvex as a research correlator: signed EventEnvelopes, weak detectors (lateral auth, micro-exfil, recon), optional cross-host fusion, quarantine dry-run only. Explicit non-goals: not EDR replacement, not LLM detection, not enterprise-validated. Audience gets enough architecture to trust later tables without drowning in code.

8-14 min - Protocol. Walk five controls: (1) Fernet-sealed held-out packs; (2) detector-only ablation; (3) breaktest manifests with public TTP IDs; (4) external OTRF / ATT&CK Evals as the independence headline; (5) claim_allowed predicates on disk. Emphasize authorship tiers - sealed and breaktest are still author-assembled; OTRF is external origin but still lab purple-team.

14-22 min - Results that survive peer pressure. Sealed N=6 attack / N=6 benign: correlator micro-F1 1.00 vs detector-only 0.625. Breaktest: ~0.65 vs ~0.20 (lift ~+0.44). Broad OTRF atomics: campaigns form, but 34/36 show no host-coverage lift - say so. Aggressive compounds: 4 FUSION_HELD (APT29 day1/day2, Caldera APT3, Golden SAML), 10 single-host (fusion not testable), 0 fleet-wide quarantine spray after fixes. Live laptop stress: 56 OTRF replays into a running correlator - 20 caught, 19 already covered, 17 single-host batches, 0 miss. Clarify replay vs live malware.

22-27 min - Named failures + takeaways. Mechanisms: ambient cloud-metadata micro-exfil poison, recon host-union mega-camps, fleet-wide dry-run quarantine, adapter allowlist skip rates on APT29, high-volume egress bury still broken on some author cells. Hand the audience a one-page claim checklist they can apply to any internal detection project.

27-30 min - Close. Re-state locked claim. Point to open repo and reproduce commands. Invite hard questions about what is still missing (second physical host, benign baseline PASS/FAIL).

Q&A (5 min). Prefer questions on metric honesty, quarantine cut-points, and how to port the protocol without Corvex.

What problem / who benefits / why this speaker

- **Problem:** Detection engineering and research tooling overclaim from small synthetic wins; IR teams inherit inflated confidence.
- **Benefit:** CSIRT/SOC detection engineers, purple teams, and student builders get a portable seal/ablate/external/gate checklist and concrete failure patterns.
- **Qualification:** Built and open-sourced Corvex end-to-end (correlator, Windows/macOS observe-only sensors, sealed eval, OTRF adapters, claim gates); ran APT29/APT3 external batteries and live replay stress on a Windows laptop; revised after CSET-style claim-production critique (inconsistent F1, author-only tests, BROKE-without-why, lab-to-field drift).

2. The problem in plain language

Incident responders and detection engineers live under two pressures that fight each other. On one side, leadership wants confidence: "does this catch multi-host campaigns?" On the other side, honest telemetry is messy, sparse, and rarely labeled. Lab packs fill the gap. That is fine - until the lab number becomes the sentence on a README, a slide, or a vendor brief.

Call the failure mode **lab-to-field language drift**. A correlator scores perfectly on six sealed synthetic packs. Someone writes "works on multi-host attacks." A reader hears "enterprise-ready." Nothing in the math forced the lie; the packaging did.

FIRST audiences already know purple-team captures are not production estates. The contribution here is making the stop between score and sentence **executable**: seal answers, ablate fusion, prefer external corpora, name failure mechanisms, and keep a machine gate that refuses field language until second-host evidence exists.

> **Audience takeaway (early)**
> Treat every detection F1 as a claim about a specific authorship tier and sample size. If the abstract upgrades the tier, the abstract is wrong - even if the F1 is correct.

3. What Corvex is (and is not)

Corvex is an open-source research correlator. Hosts emit HMAC-signed **EventEnvelope** records. Per-host detectors raise weak signals (lateral authentication, micro-exfiltration, recon fanout, optional DNS beacons). A correlator optionally merges those signals across hosts using time windows, hop graphs, ambient-destination poison, and anti-jumpbox rules. Quarantine proposals exist only as **dry_run / lab_flag / blocked**. Live OS containment defaults off (`CORVEX_CONTAIN=0`). Windows and macOS Stage B sensors are observe-only. ATT&CK tags are coarse stage hypotheses, not high-confidence attributions.

Terminology used in the rest of this brief

Term	Meaning
Correlator	Fusion path - cross-key / cross-host merge
Detector-only	Same alerts, grouped by detector key without that merge
Breaktest	Public-TTP-shaped manifests (author-assembled)
OTRF corpus	Externally authored Mordor / Security-Datasets / ATT&CK Evals
Claim gate	On-disk predicates evaluated by `corvex claim-gates`

Table 1. Shared vocabulary. Use these terms when asking questions in the talk.

Not claimed: commercial EDR/XDR parity; enterprise telemetry validation; live malware catch on a laptop; automatic containment that is safe to enable.

4. Evaluation protocol

Five parts. None of them is theoretically novel alone. Together they make claim discipline reproducible from a clean clone.

4.1 Seal held-out packs

Generators write JSONL packs. Packs and scorer rules are Fernet-sealed under an external key before correlator retunes. Sealing reduces accidental train/test snooping. It does **not** create outsider authorship. Current sealed size: attack N=6 (lateral x2, exfil x2, fusion_chain, recon_lateral) and benign N=6. Still synthetic; still modest.

4.2 Detector-only ablation

Score the same events with fusion disabled. Fusion lift is correlator micro-F1 minus detector-only micro-F1 when ground truth exists. On OTRF packs without Corvex-authored GT, use observational verdicts (host coverage, consolidation, quarantine spray) instead of inventing F1.

4.3 Breaktest (harder, still author-assembled)

Manifests under `labs/breaktest/` cite public Atomic / ATT&CK technique IDs. Results are published even when worse than sealed. Necessary for a non-author fusion gate; still not stranger enterprise traffic.

4.4 External open-source captures (primary independence)

OTRF/Security-Datasets and MITRE ATT&CK Evals Caldera/manual captures are fetched, sanitized (CommandLine/ScriptBlockText stripped for Defender), adapted, signed under lab enrollment, and scored observationally. Catalog size as of this brief: 76 entries. This is the independence headline - not Fleet20.

4.5 Claim gates

`claim_allowed` requires non-author fusion lift, human Ed25519 stranger attestation, sealed benign FCR with minimum N, trust integrity probes, and `reports/live_second_host.json` from elevated wevtutil on a **second physical** Windows host. Lab unlock for sensors does not flip the claim bit. A drafted marketing sentence is demonstrated blocked today.

> **Blocked sentence (demo)**
>
> Drafted: "Corvex works on real multi-host attacks in enterprise networks and is ready for production SOC use." Gate today: claim_allowed=false (live_second_host fail). Allowed sentence remains the standing claim. Reproduce: `python scripts/demo_blocked_claim.py`

5. Results (numbers with authorship)

Every table below names N and authorship. Micro-F1 means the harmonic mean of pooled precision and recall from TP/FP/FN - not the mean of per-pack F1s. That bug produced impossible triples (e.g. P~0.33, R~0.67, F1~0.67) in an earlier draft and is fixed.

5.1 Sealed held-out (synthetic, author-generated, sealed)

Metric	Correlator	Detector-only	B1 single-host
Precision (micro)	1.00	0.50	0.00
Recall (micro)	1.00	0.83	0.00
F1 (micro)	**1.00**	**0.625**	0.00

Metric	Correlator	Detector-only	B1 single-host
Benign FCR (N=6)	0.00	-	-

Table 2. Perfect correlator F1 on N=6 is necessary but not sufficient. Fusion still matters (lift +0.375 vs detector-only). Absolute score remains a small synthetic upper bound.

5.2 Breaktest / public-TTP (author-assembled, harder)

Metric	Correlator	Detector-only
Precision (micro)	~0.50	~0.13
Recall (micro)	~0.91	~0.45
F1 (micro)	**~0.65**	**~0.20**
F1 lift	**~+0.44**	-

Table 3. Same metric, harder packs. Drop from sealed 1.00 to ~0.65 is the point - publish it. Source: reports/non_author_fusion.json.

5.3 Broad OTRF atomics (external; observational)

On 36 Empire / Covenant / PurpleSharp / native + Caldera APT3 corpora, multi-host campaigns form readily - but the current scoreboard is honest about fusion:

Verdict / break	Count	Read
MULTI_HOST_NO_LIFT	34	Camps form; no host-coverage lift vs detector
SINGLE_HOST	2	Fusion not testable
Q_DRYRUN_ALL_HOSTS	30	Dry-run often marks every host (pre-fix pressure)
ADAPTER_HEAVY_SKIP	26	Channel allowlist drops many raw events

Table 4. Do not lead independence claims with "it worked on OTRF" without this table. These failures drove the correlator/quarantine fixes measured next.

5.4 Aggressive compounds (APT29 / APT3 / Golden SAML / …)

Verdict	N	Meaning
FUSION_HELD	4	APT29 day1, APT29 day2, Caldera APT3 day1, Golden SAML - consolidation + surgical Q
SINGLE_HOST	10	Empire APT3 compound, 7x LSASS, Log4Shell x2 - fusion not testable
FUSION_NO_LIFT / Q-all-hosts	0	After ambient poison, hop peers, no recon-union, cut-point Q

Table 5. On saturated 4-5 host labs, host-coverage lift can be definitionally zero when both arms already cover all hosts. HELD here means consolidation + surgical quarantine, not "more hosts than detector." APT29 adapter skip rates remain high (~0.86-0.94) - allowlist noise, still a remaining break type.

5.5 Live laptop stress (correlator running + OTRF replay)

> **Mode honesty**
> offline_lab_replay_into_live_correlator - captures are replayed into a live Corvex process and dash on the author's Windows laptop. This is **not** executing Empire/Covenant/malware on that laptop.

Catch label	N of 56	Meaning
CAUGHT	20	New multi-host bridge / camp growth
ALREADY_COVERED	19	Attack hosts already inside multi-host camps
SINGLE_HOST_BATCH	17	Capture has <2 hosts - fusion not required
MISS	**0**	No multi-host capture failed to register

Table 6. Final live snapshot: 139,594 events; 55 multi-host campaigns spanning APT29, Caldera, Mordor workstation, and Golden SAML hostnames. Dash left on :8765 during the run.

5.6 Author fleets (secondary engineering probes only)

Fleet20: 20 HELD (fragile_rate 0.05) - never report bare 20/20. Intensive multifactor: HELD 23 (fragile 5), PARTIAL 2, BROKE 3 (exfil_bury). Useful for mechanism debugging. **Not** the independence headline.

6. What broke and why

Earlier packaging named BROKE without mechanism. Reviewers rightly rejected that. Table 7 is the condensed WHY list IR engineers can argue with.

Mode	Mechanism	Status
DHCP hostname split-brain	Distinct host_id strings; multihost enrollment refuse	HELD (runtime aliases)
Day-scale sleeper	1h resume fragmented long chains	HELD (separate sleeper resume)
Shared svc-account glue	Time window glued disjoint hop islands	Unit HELD (hop partition)
High-volume egress bury	CDN-like dst fanout swallows needle	Unit poison HELD; some intensive cells still BROKE
DNS-only C2	No Sysmon EID 22 -> no DNS events	Honest channel_health.dns GAP
Fleet-wide Q dry-run	Recon union + egress-on-all-hosts spray	Fixed: annotate-only recon; cut-point Q
Ambient metadata micro-exfil	169.254.169.254 / Azure wire free multi-host coverage	Fixed: ambient poison in detectors + correlator
APT29 adapter skip	Channel allowlist drops majority of raw events	Remaining - report skip_rate

Table 7. Condensed from docs/stress-failure-modes.md. Prefer mechanism sentences in any talk slide that shows red cells.

7. What IR teams can steal tomorrow (without Corvex)

- **Authorship column on every scoreboard.** Author-synthetic / author-breaktest / external-lab / stranger-enterprise - never mix tiers in one headline number.
- **Micro-F1 only for headline.** If P and R are pooled, F1 must be 2PR/(P+R) from those same pools. Macro mean of pack F1s is diagnostic only.
- **Always ablate fusion.** A correlator that cannot beat detector-only on the metric you care about has not earned a fusion claim.
- **External corpora before self-fleets.** Prefer OTRF / ATT&CK Evals / Atomic before author purple scripts when arguing independence.
- **Name failure mechanisms.** "BROKE" is a status; "CDN egress bury drowned the needle" is engineering.

- **Claim gate as release criteria.** Even a shell script that greps for required evidence files beats social pressure to soft-upgrade the README.
- **Quarantine cut-points.** If dry-run proposes every host, your automation is not ready for human trust - fix the spray before enabling action.
- **Replay honesty.** Streaming sanitized captures into a detector is not the same as catching a live implant. Say which one you ran.

8. Limits (say these out loud)

- Sealed attack N=6 is expanded but still modest.
- Sealed and breaktest packs remain primarily author-generated.
- OTRF packs are external in origin but still lab purple-team - not enterprise estates.
- Broad OTRF atomics still show MULTI_HOST_NO_LIFT at scale; aggressive HELD does not rewrite that table.
- No enterprise telemetry in this brief; second physical Windows host evidence deferred.
- Home-lab benign PASS/FAIL against pre-committed bars not yet a claim softener.
- Claim lock is auditable process, not DRM - a determined author can forge files.
- Live stress is replay, not live malware execution on the laptop.

Venue map (shortlist context)

Primary for this PDF: FIRST Technical Colloquium Bangalore 2027 - practitioner talk; abstract + outline required; formal paper optional; this brief is supporting material. **Secondary academic track:** CSET-style claim-production workshops (prior packaging rejected; revision checklist lives in-repo). SaTML-style ML venues were a poor fit for this correlator story and are not the focus here.

Reproduce (clean clone)

```
pip install -e ".[dev]"
corvex seal-day0 --force && corvex eval --split heldout
corvex score-non-author && corvex claim-gates
python scripts/fetch_opensource_corpora.py --aggressive
python scripts/run_opensource_attack_eval.py --aggressive
python scripts/fetch_opensource_corpora.py --live-stress
python scripts/run_live_opensource_stress.py --dash
python scripts/demo_blocked_claim.py
```

Artifact: https://github.com/Siddarthb07/corvex · Full academic draft: docs/CORVEX_PAPER_DRAFT.md · Checklist: docs/CSET_REVISION_CHECKLIST.md

Appendix - Why earlier academic packaging was rejected

This appendix is for program-committee members who want the revision trail. It is not required reading for the live talk.

Critique	Symptom in v1	Response now
Inconsistent F1	Macro mean of pack F1s with micro P/R	Micro F1 = 2PR/(P+R); macro diagnostic only
N too small	Tiny sealed attack set	N=6 attack / N=6 benign; still labeled modest
Author-written tests	Fleet20 as the headline	OTRF / ATT&CK Evals lead; fleets secondary
BROKE without why	Red cells, no mechanism	stress-failure-modes.md + Table 7
Lab-to-field drift	F1=1.00 soft-upgraded	Standing claim + claim_allowed=false + blocked demo
Missing ablation / OOD	Fusion asserted alone	Detector-only tables; breaktest drop; aggressive battery
Novelty overclaim	Read as SOTA IDS	Experience report / protocol around open correlator

Table 8. Rejection-to-response map. Full checklist: docs/CSET_REVISION_CHECKLIST.md.

Closing line for the talk, if needed: synthetic security evaluations need hard stops between lab scores and field claims. Seal, ablate, prefer external corpora, name mechanisms, and keep the claim bit false until second-host evidence exists. That discipline travels farther than any single correlator score.

Document version 2026-10-24 · Numbers from in-repo reports after micro-F1 fix and OTRF / live-stress batteries · claim_allowed=false